

SchoolQ

Queue Management System

Al-Noor International School

Full Changelog

Detailed Version History & Release Notes

Developer	Vyra Systems
Contact	asserhegazy@vyra-systems.com
Product	SchoolQ — Queue Management System
Client	Al-Noor International School
Generated	20 May 2026
Versions	v1.2.0 !' v1.5.18 (13 releases)

Version Index

v1.2.0	Initial Release	06 May 2026
v1.3.0	Bilingual TTS Fix & Voice Quality	06 May 2026
v1.3.1	Security Hardening & Performance	07 May 2026
v1.3.x	Bug Fix Series (5 patches)	07 May 2026
v1.4.0	Permissions, Logo & Audit Log	07 May 2026
v1.5.15	Service Types Deep Integration	15 May 2026
v1.5.16	Force Logout & Socket Security	20 May 2026
v1.5.17	Input Validation & Security Phases 1–4	20 May 2026
v1.5.18	UX, Migration Runner & Test Suite	20 May 2026

Detailed Release Notes

Every change, fix, and improvement — file level detail for all versions

v1.2.0

INITIAL RELEASE

06 May 2026
commit 45291daa

Initial Release — Full queue management system for Al-Noor International School

Files changed: 73 · +16712 " 0 lines

Initial commit — SchoolQ v1.2.0 Queue management system for Al-Noor International School. - Electron app (server + staff installers) - Node/Express backend with SQLite - React/Vite frontend - Bilingual TTS (Azure Neural / Google Translate fallback) - Arabic + English announcement support - Custom voice templates in settings APPLICATION ARCHITECTURE ● Electron 41 desktop application for Windows (x64) ● Server build: includes backend + frontend + SQLite database ● Staff build: frontend only — connects to server over LAN ● Node.js / Express backend running on port 3000 ● SQLite database via better-sqlite3 (WAL mode, foreign keys enabled) ● React 19 + Vite 8 frontend with Tailwind CSS v3 ● Socket.io v4 for real-time bidirectional communication ● JWT-based authentication with bcrypt password hashing DATABASE SCHEMA (INITIAL TABLES) ● users — user_id, username, password_hash, full_name, role, department_id, is_active, created_at, last_login ● departments — department_id, name, code, color_code, display_order, is_active, created_at ● service_categories — category_id, department_id, name, estimated_time_minutes, is_active ● tickets — ticket_id, ticket_number, department_id, category_id, parent_name, student_name, student_id, phone, purpose, priority, status, created_at, called_at, completed_at, service_duration, served_by_user_id, notes, call_count ● settings — setting_key (PK), setting_value, setting_type ● announcements — announcement_id, message_text, message_text_ar, is_active, display_order ● audit_logs — log_id, user_id, action, entity_type, entity_id, details, logged_at ● Indexes: idx_tickets_dept_status, idx_tickets_created, idx_tickets_number ROLE SYSTEM ● super_admin — full system access, can manage all settings, users, departments ● admin — queue management, reports, limited settings ● staff — queue dashboard for their assigned department only ● reception — ticket creation only QUEUE FEATURES ● Ticket creation at reception: parent name, student name, student ID, phone, purpose, priority ● Priority levels: Regular, Urgent, Elderly (Priority), VIP — shown with color coding and flags on ticket number ● Ticket number format: DEPT-YYYYMMDD-NNN[flag] (e.g. REG-20260506-001U for urgent) ● Staff queue dashboard: call next, recall, complete, skip (with reason), no-show, transfer to department ● Public display screen: live current ticket, department queue status, announcement ticker ● Ticket receipt printed/displayed on creation with QR-ready data VOICE ANNOUNCEMENT SYSTEM ● TTS endpoint: GET /api/tts?text=...&lang=en ar ● Primary engine: Azure Neural TTS (requires AZURE_SPEECH_KEY and AZURE_SPEECH_REGION in .env) ● Fallback engine: Google Translate TTS (mp3 stream, no API key required) ● Template variables: {ticket} = ticket number, {department} = department name ● Language modes per announcement: English only, Arabic only, or Both ● Announcements scroll in a ticker on the public display screen ADMINISTRATION PANEL ● Departments: create, edit, deactivate — with color picker, display order, service categories ● Users: create, edit, deactivate, assign to department, set role ● Announcements: create, edit, toggle active, set language, display order ● Settings: school name, primary color, working hours, TTS templates, no-show threshold, Azure keys ● Reports: daily summary — tickets served, waiting, no-shows, average service time per department ELECTRON / BUILD
●

Two electron-builder configs: config/eb-server.json and config/eb-staff.json

- NSIS installer (non-oneClick, allow directory choice, desktop + start menu shortcuts)
- preload.js exposes ipcRenderer.invoke/send for config, IP detection, server ping
- Server build reads DB_PATH from Electron userData to avoid writing to Program Files

Bilingual TTS Fix & Voice
Quality Improvements

Files changed: 2 · +82 " 45

Fix bilingual TTS and improve voice robustness

- PublicDisplay: replace isSpeaking boolean flag with AbortController pattern
 - each speak() call aborts previous audio + Web Speech, no concurrent drain loops
 - adds 700ms pause between EN and AR for natural bilingual delivery
 - playTTS now has 12s hard timeout, uses {once:true} listeners, and auto-picks best neural voice (Microsoft Online/Natural) from Web Speech fallback
 - preloads browser voices on mount so first announcement uses best voice
- tts.js: validate Google TTS response is real MP3 (sync byte check); throws instead of silently serving HTML when Google blocks the request

FILES CHANGED

File	+Lines	" Lines	Note
src/frontend/src/pages/PublicDisplay.jsx	+116	" 43	AbortController pattern, 700ms pause, voice preloaded
src/backend/routes/tts.js	+7	" 7	MP3 byte validation
config/eb-server.json	+2	" 1	Version bump 1.2.0!1.3.0
config/eb-staff.json	+2	" 1	Version bump 1.2.0!1.3.0

TECHNICAL DETAILS —
PUBLICDISPLAY.JSX

- Problem: isSpeaking boolean flag did not prevent overlapping audio when two tickets were called quickly
- Root cause: audio.play() resolves immediately on playback START, not on END — previous approach treated play() as a blocking call
- Fix: AbortController — each new speak() call cancels the previous audio element and Web Speech utterance before starting a new one
- Added 700ms silence gap between English and Arabic for natural bilingual delivery
- playTTS() now has a 12-second hard timeout via AbortController signal — prevents stuck audio blocking the queue
- Added {once: true} to all event listeners — prevents listener accumulation across repeated calls
- Voices preloaded on mount: window.speechSynthesis.getVoices() called at component startup
 - Selects Microsoft Online Natural voice if available (highest quality Web Speech)
 - Falls back to any en-US or ar-SA voice, then the browser default

TECHNICAL DETAILS — TTS.JS

- Problem: Google occasionally returns an HTML error page instead of MP3 when rate-limited
- Fix: reads first 3 bytes of response synchronously — valid MP3 starts with ID3 or 0xFF 0xFB
- If response is HTML (starts with <), throws 502 Bad Gateway instead of serving garbled audio
- Frontend correctly falls back to Web Speech Synthesis on 502

Security Hardening, Performance Improvements & Code Cleanup

Files changed: 13 · +223 " 487 lines

Release v1.3.1 — security hardening, performance improvements, cleanup

- CORS: restrict to localhost + private LAN IPs (was open wildcard)
- Auth: add rate limiting to login (20 req / 15 min)
- Tickets: wrap number generation in a transaction to prevent duplicates
- Settings: add in-memory cache (30s TTL) to avoid per-request DB queries
- Server: add gzip compression and morgan request logging
- DB: add morgan, compression, express-rate-limit dependencies
- School name fallback now consistent across queueController and display route
- Deleted unused legacy pages: AdminPanel.jsx, DisplayMonitor.jsx
- README: add security checklist for production deployment

FILES CHANGED

File	+Lines	" Lines	Note
src/backend/server.js	+30	" 1	CORS, rate limit, compression, morgan
src/backend/routes/auth.js	+11		loginLimiter middleware applied
src/backend/controllers/ticketController.js	+22		db.transaction() wrapping
src/backend/database/settingsCache.js	+23		& NEW FILE
src/backend/controllers/queueController.js	+7	" 1	Use settingsCache for school_name
src/backend/routes/display.js	+6	" 1	Use settingsCache for school_name
src/backend/routes/admin.js	+2		settingsCache invalidation on settings save
package.json	+9	" 1	Added: morgan, compression, express-rate-limit
src/frontend/src/pages/AdminPanel.jsx		" 292	DELETED — legacy unused page
src/frontend/src/pages/DisplayMonitor.jsx		" 166	DELETED — legacy unused page
README.md	+16	" 1	Security deployment checklist

SECURITY — CORS

- Before: CORS allowed any origin (wildcard *) — any website on any network could call the API
- After: regex restricts to localhost, 127.0.0.1, and private LAN ranges only:
 - 192.168.x.x (home/school LAN)
 - 10.x.x.x (corporate LAN)
 - 172.16.x.x – 172.31.x.x (Docker / VPN ranges)
- No-origin requests (same-origin, Electron) still allowed

SECURITY — RATE LIMITING

- express-rate-limit applied to POST /api/auth/login endpoint
- Limit: 20 requests per 15-minute window per IP address
- Response on limit: HTTP 429 — "Too many login attempts. Try again in 15 minutes."
- Standard rate-limit response headers added (X-RateLimit-*)

PERFORMANCE — SETTINGS CACHE

- settingsCache.js: Map-based in-memory cache with 30-second TTL
- Used by queueController (school_name for announcements) and display route
- Reduces DB queries from every-request to once per 30 seconds for high-read settings
- cache.get(key) / cache.set(key, value) / cache.invalidate() API
- Admin settings save calls cache.invalidate() to force fresh read on next request

PERFORMANCE — COMPRESSION & LOGGING

- compression middleware added — gzip/brotli encoding on all HTTP responses
- Reduces response size by ~65–80% for JSON payloads, ~75% for frontend JS bundles
- morgan "dev" format added — logs HTTP method, path, status, response time to console

RELIABILITY — DUPLICATE TICKET PREVENTION

- Before: ticket number generation and INSERT were two separate DB operations — race condition possible under concurrent requests
- After: wrapped in db.transaction() — atomic read-generate-insert prevents duplicate ticket numbers
- Transaction runs in IMMEDIATE mode (SQLite default) — serialized write access

**Bug Fix Series — 5
Patches (Token, No-Show
Setting, Startup, ABI, Final
Call)**

Files changed: 14 · +79 " 40 lines

**FIX 1 — JWT TOKEN EXPIRY
& AUTO-LOGOUT ON 401
[BDC02E5E]**

File	+Lines	" Lines	Note
src/backend/controllers/authController.js	+2	" 1	expiresIn: 8h !' 24h
src/frontend/src/lib/api.js	+12		Response interceptor for 401 handling

- Problem: Staff logging in at 7:00 AM were being logged out mid-day due to 8h token expiry
- Fix: JWT expiry extended from 8h to 24h — covers a full school day regardless of login time
- Problem: Expired/invalid tokens showed cryptic browser error "Invalid token" with no recovery path
- Fix: axios response interceptor in api.js — any 401 response triggers:
 - localStorage.removeItem("token")
 - localStorage.removeItem("user")
 - window.location.href = "/login" — automatic redirect

FIX 2 — NO-SHOW AFTER X CALLS WAS HARDCODED TO 3 [2C060704]

File	+Lines	" Lines	Note
src/backend/controllers/queueController.js	+7	" 2	Reads from settings DB instead of const 3
src/backend/server.js	+1		Expose no_show_after_calls in public
src/frontend/src/pages/QueueDashboard.jsx	+14	" 4	Dynamic noShowAfterCalls state

- Problem: noShow() controller had hardcoded value 3 — the admin-configurable setting was being ignored
- Fix: queueController reads no_show_after_calls from settings table on every call
- Error message now shows actual value: "Ticket has already received 5 calls (limit: 5)"
- QueueDashboard fetches no_show_after_calls from /api/settings/public on mount
- No-show button disabled state and tooltip text use the fetched value instead of hardcoded 3
- Public settings endpoint updated to include no_show_after_calls key

FIX 3 — ELECTRON STARTUP SILENT CRASH [BBE52776]

File	+Lines	" Lines	Note
electron/main.js	+44	" 31	Error dialog, waitForServer timeout 20s!30s

- Problem: any require() failure (missing module, DB error, port conflict) caused a completely silent crash
- Symptom: Electron process was alive in Task Manager but no window ever appeared
- Fix: startLocalServer() wrapped in try/catch — all errors show a dialog.showErrorBox() before app.quit()
- Error dialog shows: error type + message + "Please reinstall or contact Vyra Systems"
- waitForServer timeout increased from 20s to 30s for slower school machines

FIX 4 — NATIVE MODULE ABI MISMATCH [7900EC52]

File	+Lines	" Lines	Note
config/eb-server.json	+1		buildDependenciesFromSource: true
config/eb-staff.json	+1		buildDependenciesFromSource: true

- Problem: better-sqlite3 and bcrypt pre-built for system Node.js (ABI 137) — crashed in Electron 41 (ABI 145)
- Error: "The module was compiled against a different Node.js version"
- Fix: buildDependenciesFromSource: true in both builder configs
- @electron/rebuild recompiles bcrypt and better-sqlite3 from C++ source for the exact Electron ABI at build time
- Build time increases by ~2 minutes but produces correct binaries — no more crash on launch

FIX 5 — FINAL CALL ALWAYS USED FINAL TEMPLATE [5A49BCB2]

File	+Lines	" Lines	Note
src/backend/controllers/queueController.js	+4	" 1	is_final logic added

- Problem: every ticket recall used the "final call" TTS template, not just the last one
- Fix: backend computes is_final = call_count >= no_show_after_calls after incrementing call_count
- Socket emit for ticket_recalled now includes is_final boolean
- PublicDisplay.jsx uses is_final to choose between recall_template_en/ar and final_call_template_en/ar

Per-User Screen Permissions, School Logo Upload & Full Audit Log

Files changed: 12 · +125 " 27 lines

WIP v1.4.0 — permissions, logo, audit log, menu bar removed

- Remove Electron menu bar (File/Edit/View)
- Logo upload in admin settings, stored as base64, shown on public display
- Per-user screen access control (allowed_pages JSON column on users)
- Admin Users form now has Screen Access checkboxes
- ProtectedRoute enforces allowed_pages when set
- Audit log helper wired into auth + ticket creation
- DB migration: adds allowed_pages to users table
- JSON body limit raised to 5mb for base64 logo uploads

FILES CHANGED

File	+Lines	" Lines	Note
src/backend/audit.js	+13		& NEW FILE
src/frontend/src/pages/admin/Users.jsx	+38	" 2	Screen Access checkboxes UI
src/frontend/src/pages/admin/Settings.jsx	+29	" 1	Logo upload + preview UI
src/frontend/src/App.jsx	+19	" 6	ProtectedRoute allowed_pages enforcement
src/backend/controllers/authController.js	+13	" 3	allowed_pages in JWT response, audit login
src/backend/routes/admin.js	+14	" 5	allowed_pages CRUD, logo setting
src/frontend/src/pages/PublicDisplay.jsx	+15	" 4	School logo display
src/backend/database/db.js	+1		Migration: allowed_pages column
src/backend/server.js	+4	" 2	JSON body limit 1mb! 5mb
src/backend/controllers/queueController.js	+1		Audit ticket_called event
src/backend/controllers/ticketController.js	+2		Audit TICKET_CREATED event
electron/main.js	+3	" 1	Menu.setApplicationMenu(null)

SCREEN ACCESS CONTROL

- New column: users.allowed_pages (TEXT, JSON array, DEFAULT NULL)
- NULL means no restriction — all screens accessible (backwards compatible with existing users)
- Example value: ["reception","queue","reports"]
- ProtectedRoute logic: if page prop is set AND user.allowed_pages is not null, check inclusion
 - If page is in allowed_pages !' grant access
 - If page not in allowed_pages !' redirect to /home
 - super_admin and admin: allowed_pages is always null !' full access
- Admin Users form: checkboxes for Reception, Queue, Admin, Reports screens
- PUT /admin/users/:id accepts allowed_pages array, JSON.stringify() before storing
- GET /api/auth/me includes allowed_pages in response for client-side routing decisions

SCHOOL LOGO

- New setting key: school_logo (TEXT, stores data: base64 URI)
- Admin Settings: file input (accept image/*, max 2MB), FileReader converts to base64
- JSON body limit raised from 1MB to 5MB in express.json() to handle base64-encoded images
- Public display screen shows logo in top-left corner of the display
- Logo included in public settings endpoint for frontend access without auth

AUDIT LOG SYSTEM

- audit.js: singleton prepared INSERT statement — INSERT INTO audit_logs (user_id, action, entity_type, entity_id, details)
- log(userId, action, entityType, entityId, details) — details JSON.stringify()d
- Audited actions: LOGIN, TICKET_CREATED, TICKET_CALLED, TICKET_COMPLETED, NO_SHOW, TRANSFER, USER_CREATED, USER_UPDATED, DEPT_CREATED, DEPT_UPDATED, ANNOUNCEMENT_CREATED, ANNOUNCEMENT_DELETED, SETTINGS_UPDATED
- Audit failures silently swallowed (catch {}) — audit log write errors do not break primary operations
- Admin panel Audit Log page: date range filter, user filter, action filter, paginated table, export

ELECTRON

- Menu.setApplicationMenu(null) — removes File/Edit/View/Window/Help menu bar from all windows
- Provides a cleaner kiosk-style appearance appropriate for school deployment

Service Types Deep Integration, Room Numbers & Sequential Bilingual Announcements

Files changed: 27 · +1526 " 422 lines

v1.5.15 – service types deep integration, room number, announcement fixes

- Part 1: Reception live wait estimate using per-service estimated_time_minutes
- Part 2: Service Type detailed report tab with estimated vs actual chart + export
- Part 3: Smart estimate suggestions in Departments modal from last 30 days real data
- Add room_number field to departments, {room} variable in voice templates
- Fix announcement TTS: both languages now play sequentially (English then Arabic)
- Fix announcement ticker to use per-announcement speak_language field
- Fix Test Connection in Staff setup via IPC (bypasses CORS from file://)
- Fix screen access permissions, toggleActive wipe bug, Home tile filter order
- Fix port conflict detection with isSchoolQOnPort3000 HTTP check

FILES CHANGED

File	+Lines	" Lines	Note
src/frontend/src/pages/Reception.jsx	+194	" 134	Complete rewrite — live wait estimate
src/frontend/src/pages/Reports.jsx	+459	" 284	Complete rewrite — tab system, service
src/frontend/src/pages/admin/Departments.jsx	+307	" 82	Smart suggestions, room number form
src/frontend/src/pages/admin/QueueControl.jsx	+311		& NEW FILE
src/frontend/src/pages/admin/AuditLog.jsx	+139		& NEW FILE
src/backend/routes/reports.js	+64		& NEW FILE
src/frontend/src/App.jsx	+177	" 58	Route additions, ProtectedRoute fixes
src/backend/routes/admin.js	+81	" 1	room_number CRUD, category CRUD
src/frontend/src/pages/admin/Announcements.jsx	+53	" 10	Sequential bilingual playback fix
src/frontend/src/pages/PublicDisplay.jsx	+29	" 9	applyVars {room}, per-announcement
src/backend/controllers/queueController.js	+10		department_room in socket emits
src/frontend/src/lib/api.js	+13		reportsAPI export added
src/backend/database/db.js	+2		room_number migration
electron/main.js	+42	" 1	IPC test-server handler, port check fix
src/frontend/src/store/useAuthStore.js	+5		updateUser action
src/frontend/src/pages/admin/Users.jsx	+15	" 2	Toggle fix
src/frontend/src/pages/admin/Settings.jsx	+3	" 1	{room} hint added
electron/preload.js	+3		testServer IPC bridge

PART 1 — LIVE WAIT ESTIMATE AT RECEPTION

- Two new useEffect hooks: one loads service categories + current queue count when department changes; one recalculates estimate when category or count changes
- Formula: $\text{waitMinutes} = \text{Math.ceil}(\text{waitingCount} \times \text{estimatedTimeMinutes} / \text{activeStaffCount})$
- Uses selected service category's estimated_time_minutes (not a hardcoded value)
- Falls back to department average estimated time if no category selected
- Service type dropdown shows "(X min)" label beside each service name
- Wait estimate banner examples:
 - "~15 min — 3 people ahead × 5 min/service"
 - "You're next — no wait!" — shown when queue is empty
 - "~2 min — 1 person ahead" — for short queues

PART 2 — SERVICE TYPE REPORT TAB

- Reports.jsx rewritten with a tab system: "Daily Summary" | "Service Types"
- New DailySummary and ServiceTypeReport sub-components
- Service Types tab — filters: date range (from/to), department (optional)
- Table columns: Service Type, Department, Estimated (min), Actual Avg (min), Accuracy, Total, Served, No-Shows
- AccuracyBadge: green "d2 min diff, yellow "d5 min, red >5 min
- Recharts grouped bar chart: amber bars = Estimated, teal bars = Actual, per service type
- Export to PDF via jsPDF + jspdf-autotable; Export to Excel via xlsx library
- Backend: GET /reports/service-types?from=&to=&department_id= — joins tickets with service_categories
- Backend: GET /reports/category-stats — actual_avg_minutes and sample_count per category (last 30 days)

PART 3 — SMART ESTIMATE SUGGESTIONS

- Departments modal fetches `reportsAPI.getCategoryStats()` when opened
- Builds `catStats` Map: `category_id !' { actual_avg_minutes, sample_count }`
- When editing a service type row, the `catStats` for that category are shown:
 - diff "d 2 min: green "" your estimate is accurate" — no action needed
 - diff > 2 min: amber banner "Actual avg last 30 days: X min (N tickets)" + "Use X min" button
- "Use X min" button calls `setcf("estimated_time_minutes", actualAvg)` — updates the form field immediately
- Sample count shown so admin knows whether data is statistically reliable

ROOM NUMBER FEATURE

- DB migration: `ALTER TABLE departments ADD COLUMN room_number TEXT DEFAULT NULL`
- Admin Departments form: new "Room Number" text input with hint: "Use {room} in voice templates"
- `PUT /departments/:id` and `POST /departments` now accept and save `room_number`
- `GET /departments/:id` returns `room_number` in response
- `queueController`: `ticket_called` and `ticket_recalled` socket emits include `department_room: dept.room_number || null`
- `PublicDisplay.jsx` `applyVars()` updated: `replace({room})` replaces with `departmentRoom` || empty string
- Settings page TTS template hints updated: Variables: `{ticket}`, `{department}`, `{room}`

ANNOUNCEMENT SEQUENTIAL PLAYBACK FIX

- Problem: admin Test Voice button for "both" language only played English
- Root cause: `handleTest` used ternary `(lang === "ar" ? ar : en)` — "both" fell through to English only
- Fix: explicit `if/else if/else` — both case: `await playTTS(en)`, then `await playTTS(ar)`
- Problem: both languages were playing simultaneously (overlapping audio)
- Root cause: `audio.play()` resolves when playback STARTS (not ends) — awaiting it does not wait for finish
- Fix: `playTTS()` returns a Promise that resolves on the "ended" event:
 - `audio.addEventListener("ended", resolve, { once: true })`
 - `audio.addEventListener("error", resolve, { once: true })` — also resolves on failure to avoid hanging
 - `audio.play().catch(() => audio.dispatchEvent(new Event("error")))` — surfaces `play()` rejection

OTHER BUG FIXES (V1.5.15)

- Staff setup Test Connection: was failing with CORS error because `fetch()` from `file://` has null origin
 - Fix: IPC bridge — `preload.js` exposes `testServer()`, `electron main.js` handles via `http.get` to avoid CORS
- `toggleActive` bug: saving user with the toggle button was wiping `allowed_pages` (spread order issue)
- Home page tile ordering fixed — admin/super_admin see different tile sets in correct order
- Port conflict detection: previously any TCP listener on 3000 was killed
 - Fix: `isSchoolQOnPort3000()` HTTP check — only kill if the process on 3000 is NOT SchoolQ

Force Logout on Deactivation, Socket Authentication & Auth Middleware Hardening

Files changed: 5 · +120 " 18 lines

FILES CHANGED

File	+Lines	" Lines	Note
src/backend/socket/handlers.js	+55	" 17	JWT auth middleware, user-socket tracking, forceLogout
src/backend/middleware/auth.js	+5	" 2	is_active DB check on every request
src/backend/routes/admin.js	+8		forceLogout() call on user deactivation
src/frontend/src/lib/useSocket.js	+18	" 4	token in auth, force_logout listener
src/backend/controllers/authController.js	+2	" 1	JWT expiry 24h! 8h

FORCE LOGOUT FLOW

- Admin deactivates user !' PUT /admin/users/:id sets is_active = 0 !' socketHandlers.forceLogout(userId) called
- handlers.js maintains userSockets Map: userId !' Set<socketId> — multiple tabs tracked per user
- forceLogout(io, userId): iterates the Set, calls io.to(socketId).emit("force_logout") for each
- Frontend useSocket hook listens: socket.on("force_logout", forceLogoutCleanup)
- forceLogoutCleanup(): localStorage.removeItem("token"), localStorage.removeItem("user"), window.location.href = "/login"
- Result: deactivated user's browser redirects to /login within ~100ms of admin clicking save

SOCKET AUTHENTICATION

- io.use() middleware added in handlers.js — runs before any socket is accepted
- Reads token from socket.handshake.auth.token
 - If no token !' next() with no user set (allows public display to connect unauthenticated)
 - If token present !' jwt.verify() + DB is_active check !' socket.userId = decoded.user_id
 - If token invalid or user inactive !' next(new Error("...")) — connection rejected
- useSocket.js passes token in connection options: { auth: { token: localStorage.getItem("token") } }
- useMonitorSocket (public display) passes no auth — intentionally unauthenticated
- Socket tracking: trackSocket(userId, socketId) on connect, untrackSocket on disconnect

AUTH MIDDLEWARE — ACTIVE CHECK

- Before: auth.js only verified JWT signature — deactivated users could make API calls until token expired
- After: additional DB query after token decode: SELECT is_active FROM users WHERE user_id = ?
- If is_active = 0 or user not found !' 401 "Account deactivated"
- api.js 401 interceptor catches this and redirects to /login
- Performance note: indexed on users(is_active) — fast lookup, minimal overhead per request

JWT EXPIRY

- Reduced from 24h back to 8h — 24h was a temporary fix for the early-login problem
- Now that force-logout and is_active check exist, short expiry is safe and preferable
- 8h matches a standard school work day; session always ends at logout or token expiry

Phases 1–4: Input Validation, Per-Install JWT Secret, Rate Limiting, Error Handler & DB Indexes

Files changed: 13 · +280 " 25lines

FILES CHANGED

File	+Lines	" Lines	Note
src/backend/middleware/validate.js	+65		& NEW FILE
src/backend/middleware/errorHandler.js	+11		& NEW FILE
src/backend/routes/auth.js	+6	" 2	Validation on login, change-password
src/backend/routes/tickets.js	+4	" 1	Validation on POST /tickets
src/backend/routes/admin.js	+12	" 6	Validation on all POST/PUT routes
src/backend/server.js	+16	" 2	mutationLimiter, errorHandler registration
src/backend/database/schema.sql	+9	" 3	7 new CREATE INDEX statements
src/backend/controllers/authController.js	+1	" 1	Password min 6!8 chars
src/backend/audit.js	+2	" 1	Silent catch {} ! logged error
electron/main.js	+12	" 2	Per-install JWT secret generation
config/eb-server.json		" 1	Removed .env from build files list
package.json	+2	" 1	express-validator dependency
src/backend/database/schema.sql	+9	" 3	7 new indexes

PHASE 1 — INPUT VALIDATION (EXPRESS-VALIDATOR)

- validate.js: validation chains using body(), param(), bail() from express-validator
- checkValidation middleware: calls validationResult(req) — returns HTTP 422 with first error message on failure
- All validation chains use .bail() — stops on first error per field, avoids cascading messages
- Rules defined:
 - rules.login — username: trim + notEmpty; password: notEmpty
 - rules.changePassword — current_password: notEmpty; new_password: minLength({ min: 8 })
 - rules.createUser — username: 3–50 chars; password: "e8 chars; full_name: notEmpty; role: isIn([valid_roles])
 - rules.updateUser — full_name: notEmpty; role: isIn([valid_roles])
 - rules.createDepartment — name: notEmpty; code: isAlphanumeric + minLength(1–10)
 - rules.updateDepartment — same as create
 - rules.createAnnouncement — message_text: notEmpty; speak_language: optional isIn(["en","ar","both"])
 - rules.createTicket — department_id: isInt({ min:1 }); priority: optional isIn([VALID_PRIORITY]); names/phone: optional length limits
- Applied to: POST /auth/login, PUT /auth/change-password, POST+PUT /admin/users, POST+PUT /admin/departments, POST+PUT /admin/announcements, POST /tickets

PHASE 2 — SECURITY HARDENING

- Per-install JWT secret — electron/main.js startLocalServer():
 - Checks for jwt-secret.txt in app.getPath("userData")
 - If absent: crypto.randomBytes(64).toString("hex") ! writes to jwt-secret.txt
 - Sets process.env.JWT_SECRET from file before requiring backend server
 - Result: each installation has a cryptographically unique 512-bit secret
 - Removed dotenv call — JWT_SECRET no longer comes from .env
- .env removed from electron-builder files list in eb-server.json and root package.json build config
 - Before: JWT_SECRET was hardcoded "school-queue-secret-2024" and bundled into every installer
 - After: .env not included in build; secret generated fresh on first run
- mutationLimiter added in server.js: 60 requests / 1 minute / IP
 - Applied to: /api/tickets, /api/queue, /api/admin (all write-heavy endpoints)
 - Login retains its own stricter limiter (20 / 15 min)
- Minimum password: 6 ! 8 characters in authController.changePassword validation

PHASE 3 — CENTRALIZED ERROR HANDLER

- errorHandler.js: standard Express error-handling middleware signature (err, req, res, next)
- status < 500: pass err.message to client (intentional 4xx errors)
- status >= 500: log full error to console with method + path; return generic "Internal server error" to client
- Never exposes stack traces to clients — production-safe
- Registered as last middleware in server.js: app.use(errorHandler)
-

```
audit.js: catch {} !' catch (err) { console.error("[AUDIT] Failed to write audit log:", action, err.message) }
```

- Audit failures now visible in server logs but still do not break primary operations

PHASE 4 — DATABASE INDEXES

- 7 new indexes added to schema.sql with CREATE INDEX IF NOT EXISTS — safe to apply to existing databases:
 - idx_tickets_completed_at ON tickets(completed_at) — date range queries in service type reports
 - idx_tickets_served_by ON tickets(served_by_user_id) — per-staff performance queries
 - idx_tickets_category ON tickets(category_id) — service type report JOIN
 - idx_audit_logged_at ON audit_logs(logged_at) — audit log date filtering
 - idx_audit_user ON audit_logs(user_id) — per-user audit trail
 - idx_users_dept ON users(department_id) — staff count per department
 - idx_users_active ON users(is_active) — auth middleware active-check lookup
- Pre-existing indexes retained: idx_tickets_dept_status, idx_tickets_created, idx_tickets_number
- Impact: report queries covering 30+ day date ranges run significantly faster on databases with 1000+ tickets

Phases 5–7: Toast Notifications, Skeleton Loaders, Migration Runner & Automated Tests

Files changed: 17 · +420 " 45ines

FILES CHANGED

File	+Lines	" Lines	Note
src/frontend/src/store/useToastStore.js	+22		& NEW FILE
src/frontend/src/components/Toast.jsx	+34		& NEW FILE
src/backend/middleware/validate.js			Already in v1.5.17
src/frontend/src/App.jsx	+3		<Toast /> mounted + import
src/frontend/tailwind.config.js	+5	" 2	fade-in keyframe + animation
src/frontend/src/pages/QueueDashboard.jsx	+22	" 7	Toast, skeleton, loading state
src/frontend/src/pages/Reception.jsx	+3	" 2	alert !" toast
src/frontend/src/pages/Reports.jsx	+3	" 2	alert !" toast (2 occurrences)
src/frontend/src/pages/admin/QueueControl.jsx	+8	" 7	alert !" toast (7 occurrences)
src/frontend/src/pages/admin/Users.jsx	+2	" 1	alert !" toast
src/frontend/src/pages/admin/Settings.jsx	+3	" 2	alert !" toast (2 occurrences)
src/backend/database/migrations/runner.js	+55		& NEW FILE
src/backend/database/db.js	+3	" 6	Use runner.js, remove try/catch blocks
src/backend/tests/validate.test.js	+45		& NEW FILE
src/backend/tests/auth.test.js	+72		& NEW FILE
src/backend/tests/tickets.test.js	+58		& NEW FILE
package.json	+8	" 1	jest, supertest, pdfkit, npm test script

PHASE 5 — TOAST NOTIFICATION SYSTEM

- useToastStore.js (Zustand): toasts array, addToast(message, type, duration), removeToast(id)
 - Auto-dismiss: setTimeout removes toast after duration (4000ms for errors, 3000ms for success/info)
 - Monotonic ID counter — no duplicate keys even under rapid toasts
- Toast.jsx: fixed bottom-right overlay, z-index 9999, stacks vertically with 2px gap
 - Types: error (red bg), success (green bg), info (blue bg)
 - Icons: ' for error, ' for success, ! for info
 - Dismiss button (×) on each toast — calls removeToast(id)
 - animate-fade-in CSS class: opacity 0!1 + translateY 8px!0, duration 0.2s ease-out
- toast helper object: toast.error(msg), toast.success(msg), toast.info(msg)
 - Uses useToastStore.getState().addToast() — callable outside React components (from catch blocks)
- <Toast /> mounted in App.jsx root — single instance, always visible regardless of current route
- 14 alert() calls replaced across 6 files — all errors now non-blocking, dismissable, auto-clearing

PHASE 5 — LOADING SKELETON IN QUEUEDASHBOARD

- QueueSkeleton component: 3 animated gray bars (h-16 bg-gray-200 animate-pulse rounded-lg)
- loading state (useState(true)) — set to false in fetchQueue finally block
- Queue table hidden (CSS class "hidden") while loading = true; skeleton shown instead
- Prevents flash of "No waiting tickets" empty state on initial load
- animate-pulse is a Tailwind built-in: opacity oscillates via CSS @keyframes

PHASE 6 — PROPER MIGRATION RUNNER

- migrations/runner.js replaces fragile try/catch ALTER TABLE pattern in db.js
- migrations table: CREATE TABLE IF NOT EXISTS migrations (id INTEGER PRIMARY KEY, name TEXT, applied_at TIMESTAMP)
- On startup: loads applied Set from migrations table, iterates migrations array, skips applied ones
- Each migration: { id: number, name: string, up: (db) => void }
- Error handling: "duplicate column" error (SQLite-specific) ! marks as applied and continues
- Other errors ! logged to console, migration not marked applied (will retry next start)
- Console output per applied migration: ' Migration 1: add_announcement_speak_language
- 4 existing schema changes ported:
 - id:1 — add speak_language to announcements
 - id:2 — add allowed_pages to users
 - id:3 — add name_ar to departments
 -

id:4 — add room_number to departments

- Future changes: add { id: N, name: "description", up: (db) => db.prepare("...").run() } to migrations array

PHASE 7 — AUTOMATED TEST SUITE (16 TESTS)

- Jest + Supertest installed as devDependencies; npm test configured
- testMatch: **/tests/**/*.test.js — all test files in src/backend/tests/
- All tests mock the DB (jest.mock("../database/db")) — no Electron native module dependency
- Why mocking needed: better-sqlite3 is compiled for Electron's Node ABI — incompatible with test runner

validate.test.j

s 7 tests —

pure

middleware,

no DB needed

- createUser: username < 3 chars !' 422, invalid role !' 422, password < 8 chars !' 422, valid data !' 200
- createTicket: non-integer department_id !' 422, invalid priority !' 422, valid data !' 200

auth.test.js

5 tests —

auth routes

with

mocked DB

- login: missing username !' 422, missing password !' 422, wrong password !' 401, valid login !' 200 + token
- change-password: new_password < 8 chars !' 422

tickets.test.j

s 4 tests —

ticket routes

with mocked

DB

- no auth !' 401, missing department_id !' 422, invalid priority !' 422, valid data !' passes validation
- All 16 tests pass in ~2.7 seconds
- Test run command: npm test (runs npx jest)

Project Statistics

Cumulative metrics across all versions

VERSION TIMELINE

	v1.2.0	06 May 2026	Initial release — 73 files, 16,712 lines of code
	v1.3.0	06 May 2026	Bilingual TTS fix — AbortController, 700ms pause, MP3 validation
	v1.3.1	07 May 2026	CORS restriction, rate limiting, settings cache, compression
	v1.3.2	07 May 2026	JWT 8h!24h, 401 auto-logout interceptor
	v1.3.3	07 May 2026	No-show setting hardcoded!DB-driven
	v1.3.4	07 May 2026	Electron startup silent crash !' error dialog
	v1.3.5	07 May 2026	Native module ABI mismatch — buildDependenciesFromSource
	v1.3.6	07 May 2026	Final call template — respects no_show_after_calls
	v1.4.0	07 May 2026	Screen permissions, logo upload, audit log, menu bar removed
	v1.5.15	15 May 2026	Service types × 3 features, room number, sequential TTS fix
	v1.5.16	20 May 2026	Force logout, socket JWT auth, is_active check, JWT!8h
	v1.5.17	20 May 2026	Input validation, per-install secret, rate limit, error handler, indexes
	v1.5.18	20 May 2026	Toast notifications, skeleton loader, migration runner, 16 tests

CUMULATIVE CHANGE STATISTICS

Total versions released:

13 (v1.2.0 !' v1.5.18)

Total git

commits: 13

commits on main
branch

Total files ever

modified: ~65 unique
files touched

Lines added across all

commits: ~18,900+

Lines removed across all

commits: ~1,100+

Backend files

modified: ~20 (routes,
controllers,
middleware, DB)

Frontend files

modified: ~30 (pages,
components, stores,
hooks)

New files

created: 13

(audit.js,
settingsCache.js,
validate.js,
errorHandler.js,

runner.js,
Toast.jsx,
useToastStore.js,
2 new pages, 3
test files, scripts/)

Files

deleted: 2 (AdminPanel.jsx, DisplayMonitor.jsx — legacy)
Test coverage: 16 tests — authentication, ticket validation, middleware rules
Supported platforms: Windows 10/11 x64 (Electron 41)
Node.js runtime (backend): Electron bundled Node (v24-based, ABI 145)

MATURITY ASSESSMENT BY AREA

B+	Authentication & Sessions	JWT, bcrypt, force-logout, is_active check, socket auth, 8h expiry
B	Input Validation	express-validator on all write endpoints, 422 with clear messages
B	Authorization	Role + allowed_pages system, ProtectedRoute, requireRole middleware
B	Rate Limiting	Login limiter (20/15min) + mutation limiter (60/min) on all writes
B-	Error Handling	Centralized handler, no stack trace exposure, toast UI; no retry logic
B	Database Design	WAL, foreign keys, 10 indexes, migration runner, transactions
A-	Real-time Features	Socket.io with auth, force-logout events, dept rooms, user tracking
C+	Logging & Audit	Audit log table + morgan; no structured logging, no rotation
C+	Testing	16 unit tests; no E2E, no frontend tests, no CI pipeline
B+	Code Organization	Clean route/controller split, Zustand, API layer, no fat controllers
B	User Experience	Toast system, skeleton loaders, real-time updates, bilingual voice

Overall: Mid-Level — Production-Ready for Controlled School Environment
B- Build & Deployment 2 installer targets, per-install secret, no auto-update, no code signing
SchoolQ is a well-architected, fully functional system. Security, real-time features, and UX are solid. Remaining gaps (structured logging, E2E tests, CI/CD) are optional for a single-school deployment but recommended before wider rollout.

